SECURITY AUDIT REPORT

Lone Star Machining

CMMC Level 2 / NIST 800-171



79 of 110
controls reviewed

3
findings

22
open remediation tasks

Date	November 3, 2026
Assessment	On-Site Audit
Location	The Woodlands, TX
Auditor	Nick Mellem
Prepared by	Northline Advisory

This report records the assessor's observations and the information provided on the date shown. It is not a certification, attestation, or legal opinion, and it does not guarantee compliance with any law, regulation, or standard. Readiness-level checklists summarize their source standards and do not replace a formal assessment against the full text.

Executive Summary

Lone Star Machining has a solid foundation for protecting Controlled Unclassified Information, scoring 77% across the 79 requirements reviewed so far. Access control, configuration management, and malware protection are largely in place.

The most urgent gap is multifactor authentication: remote access still accepts password-only logins for some users. Fixing that first, then escorting visitors on the shop floor and wiping retired drives, will close the highest risks ahead of a CMMC Level 2 assessment.

RESULTS

Pass 50 | Partial 13 | Fail 10 | N/A 6 | Not Started 31

SCORE BY AREA



FINDINGS BY SEVERITY

Critical 1 | High 1 | Medium 1

Findings

CRITICAL IA 3.5.3 Multifactor authentication

1. MFA not enforced for remote access

WHAT WE FOUND

VPN accepts password-only logins for 14 of 52 users.

RECOMMENDATION

Require MFA on the VPN for all users and disable the legacy profile.

HIGH PE 3.10.3 Escort and monitor visitors

2. Visitors not escorted on the shop floor

WHAT WE FOUND

Two vendor technicians walked unescorted past the CNC area.

RECOMMENDATION

Require escorts and visitor badges beyond the lobby.

MEDIUM MP 3.8.3 Sanitize or destroy media

3. Retired drives stored without wiping

WHAT WE FOUND

A bin of 11 retired drives sits in the IT closet.

RECOMMENDATION

Wipe or shred the drives and keep certificates of destruction.

Remediation Plan

Open tasks, most urgent first.

PRIORITY	TASK	OWNER	DUE
Critical	**Fix: Multifactor authentication** IA 3.5.3	Dana	Nov 2, 2026 Overdue
High	**Fix: Control the flow of CUI** AC 3.1.3	Marcus	Nov 9, 2026
High	**Fix: Trace actions to individual users** AU 3.3.2	Unassigned	Dec 5, 2026
High	**Fix: Restrict who can make changes** CM 3.4.5	Unassigned	Dec 5, 2026
High	**Fix: No password reuse** IA 3.5.8	Unassigned	Dec 5, 2026
High	**Fix: Supervise outside maintenance staff** MA 3.7.6	Unassigned	Dec 5, 2026
High	**Fix: Limit physical access** PE 3.10.1	Unassigned	Dec 5, 2026
High	**Fix: Escort and monitor visitors** PE 3.10.3	Unassigned	Dec 5, 2026
Medium	**Fix: Limit access to authorized users, processes, and devices** AC 3.1.1	Unassigned	Jan 4, 2027
Medium	**Fix: Show privacy and security notices** AC 3.1.9	Unassigned	Jan 4, 2027
Medium	**Fix: Encrypt remote access sessions** AC 3.1.13	Unassigned	Jan 4, 2027
Medium	**Fix: Limit portable storage on external systems** AC 3.1.21	Unassigned	Jan 4, 2027
Medium	**Fix: Insider threat awareness** AT 3.2.3	Unassigned	Jan 4, 2027
Medium	**Fix: Protect logs and logging tools** AU 3.3.8	Unassigned	Jan 4, 2027

PRIORITY	TASK	OWNER	DUE
Medium	**Fix: Track and approve changes** CM 3.4.3	Unassigned	Jan 4, 2027
Medium	**Fix: Authenticate before access** IA 3.5.2	Unassigned	Jan 4, 2027
Medium	**Fix: Disable inactive identifiers** IA 3.5.6	Unassigned	Jan 4, 2027
Medium	**Fix: Test incident response** IR 3.6.3	Unassigned	Jan 4, 2027
Medium	**Fix: Scan diagnostic media** MA 3.7.4	Unassigned	Jan 4, 2027
Medium	**Fix: Sanitize or destroy media** MP 3.8.3	Unassigned	Jan 4, 2027
Medium	**Fix: Encrypt media in transport** MP 3.8.6	Unassigned	Jan 4, 2027
Medium	**Fix: Screen people before access** PS 3.9.1	Unassigned	Jan 4, 2027

Control Results

Access Control (AC) 80%

CONTROL	REQUIREMENT	RESULT
AC 3.1.1	Limit access to authorized users, processes, and devices	Partial
AC 3.1.2	Limit users to the transactions and functions they're allowed	Pass
AC 3.1.3	Control the flow of CUI Observed on site. Owner says a fix is planned but there's no ticket yet.	Fail
AC 3.1.4	Separate duties	Pass
AC 3.1.5	Least privilege	Pass
AC 3.1.6	Use non-privileged accounts for everyday work	N/A
AC 3.1.7	Block non-privileged users from privileged functions, and log it	Pass
AC 3.1.8	Limit failed logon attempts	Pass
AC 3.1.9	Show privacy and security notices	Partial
AC 3.1.10	Session lock with hidden screen content	Pass
AC 3.1.11	End sessions automatically	Pass
AC 3.1.12	Monitor and control remote access Evidence on file: MFA Configuration Screenshot	Pass
AC 3.1.13	Encrypt remote access sessions	Partial
AC 3.1.14	Route remote access through managed points	Pass
AC 3.1.15	Authorize remote privileged commands Observed on site. Owner says a fix is planned but there's no ticket yet.	Fail
AC 3.1.16	Authorize wireless access before connecting	Pass
AC 3.1.17	Protect wireless with authentication and encryption	Pass
AC 3.1.18	Control mobile device connections	N/A

CONTROL	REQUIREMENT	RESULT
AC 3.1.19	Encrypt CUI on mobile devices	Pass
AC 3.1.20	Control connections to external systems	Pass
AC 3.1.21	Limit portable storage on external systems	Partial
AC 3.1.22	Control CUI on public systems	Pass

Awareness and Training (AT) 83%

CONTROL	REQUIREMENT	RESULT
AT 3.2.1	Security awareness for all users Evidence on file: Security Awareness Training Records	Pass
AT 3.2.2	Role-based training	Pass
AT 3.2.3	Insider threat awareness	Partial

Audit and Accountability (AU) 81%

CONTROL	REQUIREMENT	RESULT
AU 3.3.1	Create and keep audit logs	Pass
AU 3.3.2	Trace actions to individual users Observed on site. Owner says a fix is planned but there's no ticket yet.	Fail
AU 3.3.3	Review and update logged events	Pass
AU 3.3.4	Alert when logging fails	Pass
AU 3.3.5	Correlate log review and reporting	N/A
AU 3.3.6	Log reduction and reporting	Pass
AU 3.3.7	Sync clocks to a trusted time source	Pass
AU 3.3.8	Protect logs and logging tools	Partial
AU 3.3.9	Limit who manages logging	Pass

Configuration Management (CM) 81%

CONTROL	REQUIREMENT	RESULT
CM 3.4.1	Baselines and inventories	Pass
CM 3.4.2	Enforce security settings	Pass
CM 3.4.3	Track and approve changes	Partial
CM 3.4.4	Analyze security impact of changes	Pass
CM 3.4.5	Restrict who can make changes Observed on site. Owner says a fix is planned but there's no ticket yet.	Fail
CM 3.4.6	Least functionality	Pass
CM 3.4.7	Restrict unneeded programs, ports, and services	Pass
CM 3.4.8	Allowlist or blocklist software	N/A
CM 3.4.9	Control user-installed software	Pass

Identification and Authentication (IA) 70%

CONTROL	REQUIREMENT	RESULT
IA 3.5.1	Identify users, processes, and devices	Pass
IA 3.5.2	Authenticate before access	Partial
IA 3.5.3	Multifactor authentication Evidence on file: MFA Configuration Screenshot	Fail
IA 3.5.4	Replay-resistant authentication	Pass
IA 3.5.5	Don't reuse identifiers	Pass
IA 3.5.6	Disable inactive identifiers	Partial
IA 3.5.7	Password complexity	Pass
IA 3.5.8	No password reuse Observed on site. Owner says a fix is planned but there's no ticket yet.	Fail

CONTROL	REQUIREMENT	RESULT
IA 3.5.9	Temporary passwords change immediately	Pass
IA 3.5.10	Store and send passwords protected	Pass
IA 3.5.11	Hide password feedback	N/A

Incident Response (IR) 83%

CONTROL	REQUIREMENT	RESULT
IR 3.6.1	Incident handling capability Evidence on file: Incident Response Plan v3	Pass
IR 3.6.2	Track, document, and report incidents	Pass
IR 3.6.3	Test incident response	Partial

Maintenance (MA) 75%

CONTROL	REQUIREMENT	RESULT
MA 3.7.1	Perform system maintenance	Pass
MA 3.7.2	Control maintenance tools and people	Pass
MA 3.7.3	Sanitize equipment sent offsite	Pass
MA 3.7.4	Scan diagnostic media	Partial
MA 3.7.5	MFA for remote maintenance	Pass
MA 3.7.6	Supervise outside maintenance staff Observed on site. Owner says a fix is planned but there's no ticket yet.	Fail

Media Protection (MP) 83%

CONTROL	REQUIREMENT	RESULT
MP 3.8.1	Protect media with CUI	Pass
MP 3.8.2	Limit access to CUI on media	Pass
MP 3.8.3	Sanitize or destroy media	Fail

CONTROL	REQUIREMENT	RESULT
MP 3.8.4	Mark media with CUI markings	Pass
MP 3.8.5	Control media during transport	Pass
MP 3.8.6	Encrypt media in transport	Partial
MP 3.8.7	Control removable media	Pass
MP 3.8.8	No ownerless portable storage	Pass
MP 3.8.9	Protect backups	Pass

Personnel Security (PS) 75%

CONTROL	REQUIREMENT	RESULT
PS 3.9.1	Screen people before access	Partial
PS 3.9.2	Protect systems when people leave or move	Pass

Physical Protection (PE) 50%

CONTROL	REQUIREMENT	RESULT
PE 3.10.1	Limit physical access Observed on site. Owner says a fix is planned but there's no ticket yet.	Fail
PE 3.10.2	Protect and monitor the facility	Pass
PE 3.10.3	Escort and monitor visitors	Fail
PE 3.10.4	Log physical access	N/A
PE 3.10.5	Manage physical access devices	Pass
PE 3.10.6	Safeguard alternate work sites	Not Started

Risk Assessment (RA) Not scored

CONTROL	REQUIREMENT	RESULT
RA 3.11.1	Assess risk periodically	Not Started

CONTROL	REQUIREMENT	RESULT
RA 3.11.2	**Scan for vulnerabilities** Evidence on file: Penetration Test Report 2025	Not Started
RA 3.11.3	**Fix vulnerabilities by risk**	Not Started

Security Assessment (CA) Not scored

CONTROL	REQUIREMENT	RESULT
CA 3.12.1	**Assess controls periodically**	Not Started
CA 3.12.2	**Plans of action**	Not Started
CA 3.12.3	**Monitor controls continuously**	Not Started
CA 3.12.4	**System security plan**	Not Started

System and Communications Protection (SC) Not scored

CONTROL	REQUIREMENT	RESULT
SC 3.13.1	**Protect network boundaries**	Not Started
SC 3.13.2	**Secure architecture and engineering**	Not Started
SC 3.13.3	**Separate user and admin functions**	Not Started
SC 3.13.4	**No leaks through shared resources**	Not Started
SC 3.13.5	**Separate public-facing systems**	Not Started
SC 3.13.6	**Deny network traffic by default**	Not Started
SC 3.13.7	**Prevent split tunneling**	Not Started
SC 3.13.8	**Encrypt CUI in transit**	Not Started
SC 3.13.9	**End idle network connections**	Not Started
SC 3.13.10	**Manage encryption keys**	Not Started
SC 3.13.11	**FIPS-validated encryption**	Not Started

CONTROL	REQUIREMENT	RESULT
SC 3.13.12	Control collaborative devices	Not Started
SC 3.13.13	Control mobile code	Not Started
SC 3.13.14	Control VoIP	Not Started
SC 3.13.15	Protect session authenticity	Not Started
SC 3.13.16	Protect CUI at rest	Not Started

System and Information Integrity (SI) Not scored

CONTROL	REQUIREMENT	RESULT
SI 3.14.1	Fix flaws on time	Not Started
SI 3.14.2	Malware protection	Not Started
SI 3.14.3	Monitor security alerts	Not Started
SI 3.14.4	Keep malware protection updated	Not Started
SI 3.14.5	Scan systems and files	Not Started
SI 3.14.6	Monitor for attacks	Not Started
SI 3.14.7	Detect unauthorized use	Not Started

Evidence Index

DOCUMENT	TYPE	EXPIRES
Incident Response Plan v3 Supports IR 3.6.1	Policy	Jun 3, 2027
MFA Configuration Screenshot Supports AC 3.1.12, IA 3.5.3	Screenshot	Nov 17, 2026
Penetration Test Report 2025 Supports RA 3.11.2	Report	Expired
Security Awareness Training Records Supports AT 3.2.1	Training Record	Dec 20, 2026